

INFORME
DE EVALUACIÓN DE SEGURIDAD

WWW.SUSCERTE.GOB.VE

INCIDENTES.VENCERT@SUSCERTE.GOB.VE

FINAL AV. ANDRÉS BELLO. ANTIGUO
EDIFICIO BFC, PISO 13, DISTRITO CAPITAL

ESTRICTAMENTE CONFIDENCIAL

Nombre del proyecto	**Corporación para el Desarrollo Científico y Tecnológico**
Fecha última edición	**23/06/2023**
Restricciones de uso	**Ver cuadro inferior**

Control de versiones

Versión	Áreas Modificadas	Descripción del cambio	Autor	Fecha
1	Todas	----------	VenCERT	23/06/2023

DERECHOS DE USO

La presente documentación es propiedad de la Superintendencia de Servicios de Certificación Electrónica SUSCERTE, tiene carácter privado y confidencial y está dirigido exclusivamente a su(s) destinatario(s), no podrá ser objeto de reproducción total o parcial, ni transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, digital, registro o cualquier otro, no podrá ser distribuido sin el permiso previo y escrito de SUSCERTE, bajo ningún concepto. Si usted ha recibido este mensaje por error, debe evitar realizar cualquier acción descrita anteriormente, asimismo le agradecemos comunicarlo al remitente y borrar el mensaje y cualquier documento adjunto. El incumplimiento de las limitaciones señaladas por cualquier persona que tenga acceso a la documentación será sancionado conforme a la ley.

ÍNDICE DE CONTENIDO

ANTECEDENTES DE LA EVALUACIÓN 04

PRELIMINAR DEL ANÁLISIS 05

NIVEL DE AMENAZAS DETECTADAS 05

RESULTADOS DE LA EVALUACIÓN 06

MEDIA

- Cabeceras de Seguridad no Implementadas 06
- Error de Validación de Origen de CORS (Intercambio de Recursos de Origen Cruzado) 08
- Slow HTTP DOS (Slowloris) 09

BAJA

- Archivos de Documentación Encontrados 11
- Marco en Línea Inseguro 12

INFORMACIÓN

- Direcciones de Correo Electrónico Encontradas 14
- Posible Divulgación de la Dirección IP Interna 16

ANTECEDENTES DE LA EVALUACIÓN

ALCANCE:

La evaluación de dicho aplicativo se basa en la seguridad y buen funcionamiento del mismo; el análisis de vulnerabilidades consta de una evaluación manual del sistema, escaneos automatizados con herramientas especializadas e investigación a profundidad, con el fin de corroborar las posibles fallas de seguridad de la información con que podría contar esta aplicación web, y por último la presentación de las recomendaciones en base a las irregularidades encontradas.

OBJETIVO PRINCIPAL:

Revisar y evaluar el portal web alojado en la URL: **https://www.codecyt.gob.ve/**

PREFACIO:

Es importante destacar que el análisis de vulnerabilidad de la aplicación web se realizará a través del método de Caja Negra, el cual consiste en que al analista se le proporciona sólo la información de acceso a la red o al sistema (podría ser sólo una dirección IP). A partir de esta información, el analista debe realizar toda la exploración y obtener toda la información posible desde dicha IP y del resto de los equipos que se encuentren en el rango asociado. Para este caso en concreto fue suministrada la URL: **https://www.codecyt.gob.ve/** como dato para iniciar la evaluación y el análisis de seguridad.

ESTRICTAMENTE CONFIDENCIAL

PRELIMINAR DEL ANÁLISIS

INFORMACIÓN DE LA EVALUACIÓN	
Sitio Web	**https://www.codecyt.gob.ve/**
Inicio	22/06/2023
Final	23/06/2023

INFORMACIÓN DEL SERVIDOR	
Respuesta del Servidor	200
Servidor Web	Nginx
Dirección IP del Servidor	200.90.11.99

Nivel de Amenazas detectadas

Nivel de las Amenazas: **MEDIO**

A través de la realización de la evaluación de seguridad se descubrió una o más vulnerabilidades de tipo de gravedad media. Debe mitigar cada una de estas vulnerabilidades para asegurarse de que no escalen a problemas más graves.

ESTRICTAMENTE CONFIDENCIAL

RESULTADOS DE LA EVALUACIÓN

Durante las pruebas realizadas se logró detectar las siguientes vulnerabilidades:

Cabeceras de Seguridad no Implementadas

Severidad	MEDIA
Tipo	Configuración

Descripción

Hay algunos encabezados de respuesta HTTP que su aplicación puede usar para aumentar la seguridad. Una vez configurados, estos encabezados de respuesta HTTP pueden impedir que los navegadores modernos se encuentren con vulnerabilidades fácilmente evitables.

Impacto

Se pueden utilizar para prevenir y/o mitigar ataques que involucran la inyección de contenido/código, como ataques de Cross Site Scripting (XSS), ataques que requieren incrustar un recurso malicioso, ataques que involucran el uso malicioso de iframes, ataques de clickjacking, ataques de degradación, ataques de intermediario, eliminación de SSL, debilitar las protecciones contra el secuestro de cookies, entre otros.

Detección	
Ruta	• https://www.codecyt.gob.ve/
Cabeceras Faltantes	• Strict-Tansport-Security • X-Frame-Options • X-XSS-Protection • X-Content-Type-Optios • Content-Security-Policy • Cache-Control

ESTRICTAMENTE CONFIDENCIAL

Comprobación	MISSING HTTP SECURITY HEADER LIST (information disclosure) Name / Value strict-transport-security: missing x-frame-options: missing x-xss-protection: missing x-content-type-options: missing content-security-policy: missing cache-control: missing

Recomendación

- Se recomienda implementar las cabeceras de seguridad en su portal web.

Referencias

- https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- https://hacks.mozilla.org/2016/02/implementing-content-security-policy/
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options

ESTRICTAMENTE CONFIDENCIAL

Error de Validación de Origen de CORS (Intercambio de Recursos de Origen Cruzado)

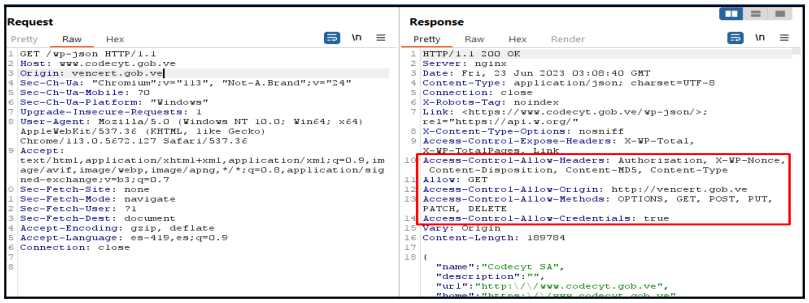
Severidad	MEDIA
Tipo	Validación

Descripción

CORS (Cross-Origin Resource Sharing) define un mecanismo para habilitar las solicitudes de origen cruzado del lado del cliente. Esta aplicación está usando CORS de una manera insegura. La aplicación web no valida correctamente el encabezado de origen y devuelve el encabezado **Access-Control-Allow-Credentials: true.**

Impacto

Un atacante puede emitir solicitudes realizadas con credenciales de usuario y leer las respuestas a estas solicitudes. Confiar en orígenes arbitrarios deshabilita efectivamente la política del mismo origen, lo que permite la interacción bidireccional por parte de terceros sitios web.

Detección	
Ruta	• https://www.codecyt.gob.ve/wp-json
Comprobación	

Recomendación

- Permitir solo dominios de confianza seleccionados en el encabezado Access-Control-Allow-Origin.

Referencia

- https://fetch.spec.whatwg.org/#http-cors-protocol

ESTRICTAMENTE CONFIDENCIAL

Slow HTTP DOS (Slowloris)

Severidad	MEDIA
Tipo	Configuración

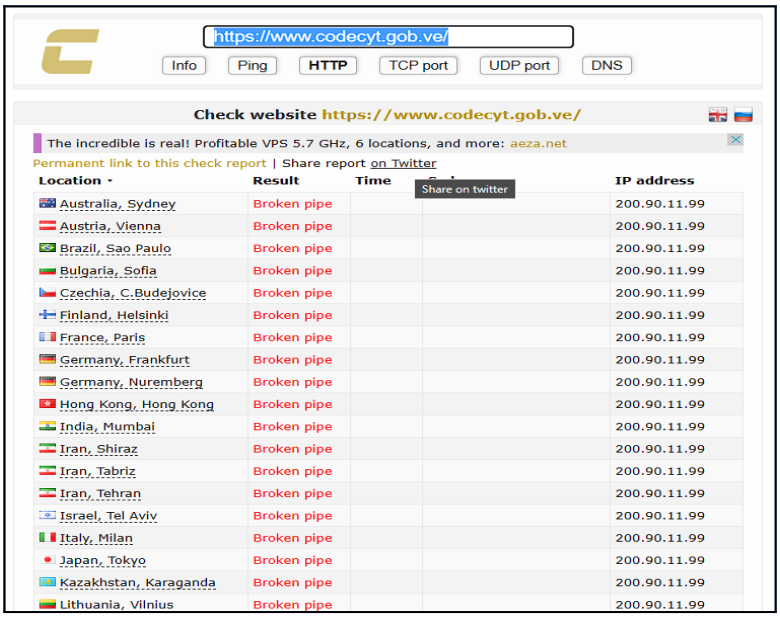
Descripción

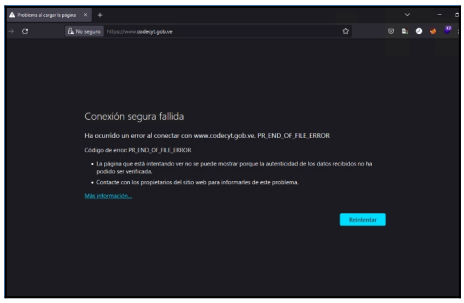
Los ataques ‘Slowloris’ y ‘Slow HTTP’ DOS, aprovechan el hecho de que el protocolo HTTP, por diseño, requiere que las solicitudes o peticiones sean recibidas completamente por el servidor antes de ser procesadas. Si una solicitud HTTP no está completa, o si la tasa de transferencia es muy lenta, el servidor mantiene los recursos reservados esperando por el resto de los datos. Si el servidor mantiene muchos recursos en reserva, esto crea una Denegación de Servicio (DOS).

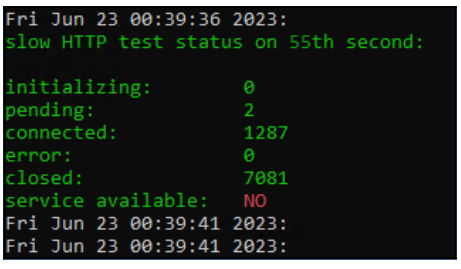
Impacto

Una sola máquina puede causar una Denegación de Servicio contra un sitio Web con esta vulnerabilidad.

Detección







ESTRICTAMENTE CONFIDENCIAL

Recomendaciones

- Usar mod_reqtimeout, mod_qos, mod_security, mod_evasive o Fail2Ban.
- Usar un aplicativo de servicio web más robusto ante ataques de denegación de servicio.

Referencia

- **http://www.techrepublic.com/blog/smb-technologist/secure-your-apache-server-from-ddos-slowloris-and-dns-injection-attacks/**

ESTRICTAMENTE CONFIDENCIAL

Archivos de Documentación Encontrados

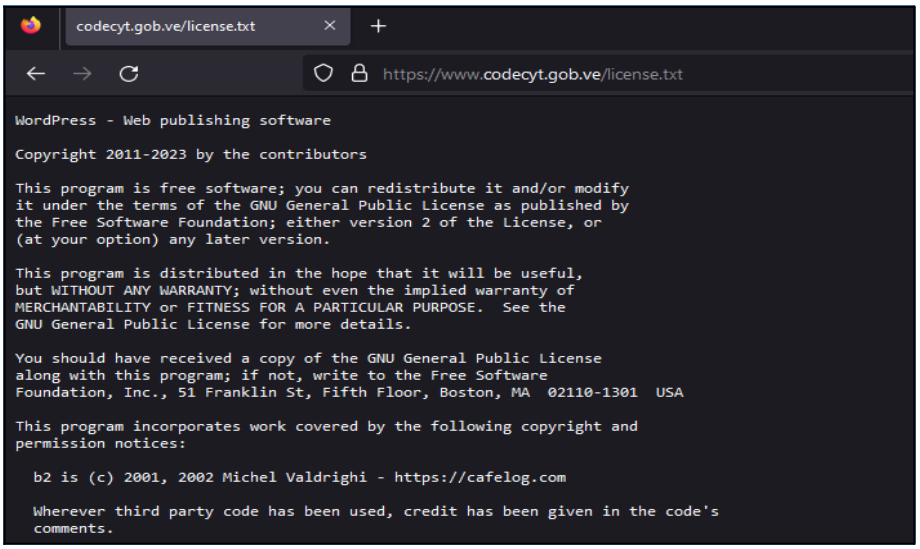
Severidad	BAJA
Tipo	Configuración

Descripción

Se encontraron archivos de documentación en el servidor (Ej: README.txt). La información contenida en estos archivos puede ayudar a un atacante a identificar la aplicación web que se está usando y/o la versión de la misma.

Impacto

Estos archivos pueden revelar información sensible que puede ser utilizada por un usuario malicioso para lanzar ataques contra la aplicación.

Detección	
Ruta	• https://www.codecyt.gob.ve/readme.html • https://www.codecyt.gob.ve/license.txt
Comprobación	

Recomendación

- Remover o restringir el acceso a archivos de documentación desde internet.

ESTRICTAMENTE CONFIDENCIAL

Marco en Línea Inseguro

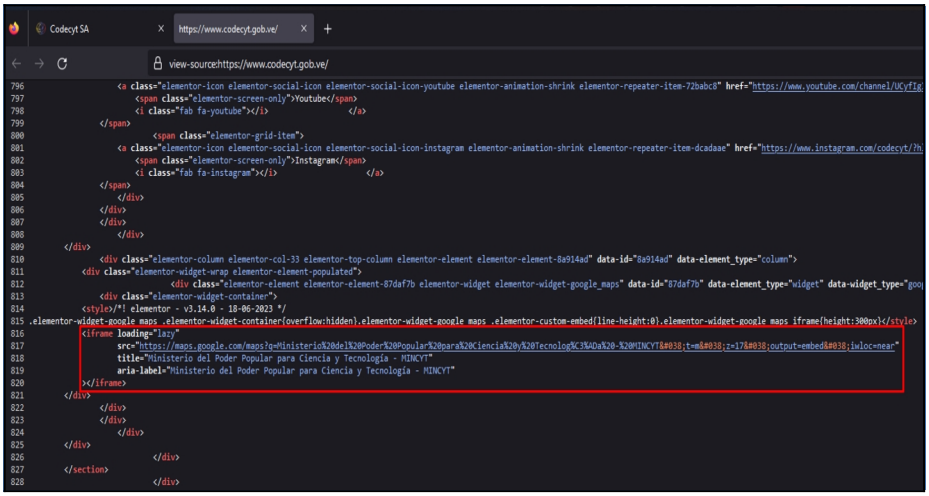
Severidad	BAJA
Tipo	Configuración

Descripción

Se descubrió que la página web usaba un marco en línea ("iframe") para incrustar un recurso, como una página web diferente. El Inline Frame está configurado de forma insegura o no tan segura como se esperaba. Esta alerta de vulnerabilidad se basa en el origen de el recurso incrustado y el atributo sandbox del iframe, que se puede utilizar para aplicar restricciones de seguridad, así como excepciones a estas restricciones.

Impacto

Cuando una página web utiliza un iframe configurado de forma insegura para incrustar otra página web, esta última puede manipular la primera, y engañar a sus visitantes para que realicen acciones no deseadas.

Detección	
Ruta	• https://www.codecyt.gob.ve/
Comprobación	

ESTRICTAMENTE CONFIDENCIAL

Recomendación

- Revisar el propósito y el entorno del iframe, y usar el atributar sandbox.

Referencias

- https://developer.mozilla.org/en-US/docs/Web/HTML/Element/iframe
- https://www.w3.org/TR/html52/semantics-embedded-content.html#element-attrdef-iframe-sandbox

ESTRICTAMENTE CONFIDENCIAL

Direcciones de Correo Electrónico Encontradas

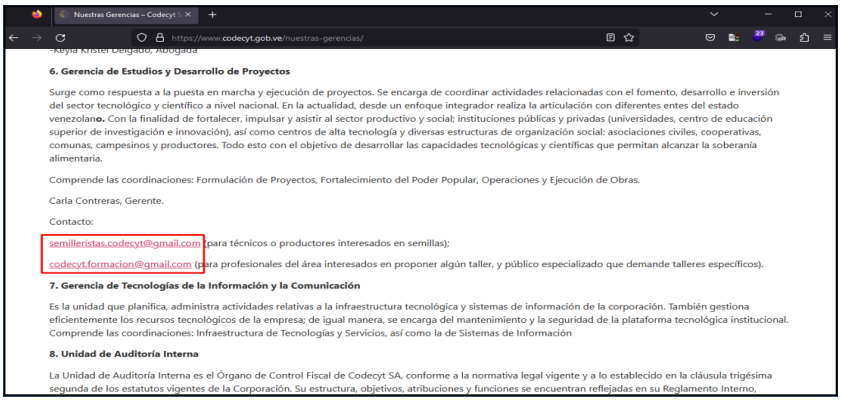
Severidad	NINGUNA
Tipo	Informativo

Descripción

Se han encontrado una o más direcciones de correo electrónico en esta página. La mayoría del spam proviene de direcciones de correo electrónico cosechadas de Internet. Los spam-bots (también conocidos como cosechadores de correo electrónico y extractores de correo electrónico) son programas que recorren Internet buscando direcciones de correo electrónico en cualquier sitio web con el que se crucen. Los programas Spambot buscan cadenas como **myname@mydomain.com** y luego registran las direcciones encontradas.

Impacto

Las direcciones de correo electrónico publicadas en los sitios web pueden atraer spam.

Detección	
Ruta	• https://www.codecyt.gob.ve/nuestras-gerencias/
Direcciones Encontradas	• talento.humano.codecyt@gmail.com • semilleristas.codecyt@gmail.com • codecyt.formacion@gmail.com • ainterna@codecyt.gob.ve • auditoria.interna.codecyt.@gmail.com
Comprobación	

ESTRICTAMENTE CONFIDENCIAL

Recomendación

- No colocar las direcciones de correo como texto plano, una alternativa puede ser usar imágenes.

ESTRICTAMENTE CONFIDENCIAL

Posible Divulgación de la Dirección IP Interna

Severidad	NINGUNA
Tipo	Informativo

Descripción

En esta página se encontró una cadena que coincide con una dirección IPv4 interna. Esto puede revelar información sobre el direccionamiento IP o el esquema de la red interna.

Impacto

Posible divulgación de información sensible, que puede utilizar para realizar más ataques.

Detección	
Ruta	• https://www.codecyt.gob.ve/nuestros-proyectos/ • https://www.codecyt.gob.ve/cropped-diseno-sin-titulo-1-png/ • https://www.codecyt.gob.ve/cropped-codecyt-1-png/
Comprobación	

Recomendación

- Evite que esta información se muestre al usuario.

ESTRICTAMENTE CONFIDENCIAL

Referencia

- https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
- https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/internal-ip-address-disclosure/

ESTRICTAMENTE CONFIDENCIAL